DuocUC

Informe de Seguridad y Calidad en el Desarrollo de Software

Angelo Millan
Evens Reneus

Calidad y Seguridad en el Desarrollo de Software

Septiembre, 2026

1. Introducción

El presente informe tiene como propósito diseñar un plan de pruebas para Atlas, una plataforma web de gestión de clientes y contratos orientada a pymes en Chile, desarrollada por CreaLab Spa. El sistema permite a usuarios registrados por empresas gestionar clientes, contratos y documentos asociados, administrar usuarios y roles internos, auditar acciones y garantizar el cumplimiento de normativas de protección de datos y estándares de seguridad.

La necesidad de realizar un plan de pruebas radica en la criticidad de la información gestionada (datos personales, bancarios y contractuales) y en la obligación de cumplir con marcos legales y normativos vigentes en Chile, como la Ley 19.628 sobre Protección de la Vida Privada y la Ley 21.096 que consagra el derecho a la protección de datos personales. Asimismo, el sistema debe ser accesible desde desktop, tablets y móviles, con especial atención a la usabilidad para adultos mayores, lo que exige pruebas de usabilidad y accesibilidad robustas.

Este informe se estructura en cuatro secciones: la presente introducción, los criterios de calidad, seguridad y cumplimiento normativo; el plan de pruebas (estrategia, tipos, criterios de aceptación y herramientas); y el diseño de al menos cinco casos de prueba representativos que cubren requerimientos funcionales y no funcionales del ERS.

El objetivo final es asegurar que Atlas cumpla con los estándares de calidad, seguridad y legalidad exigidos, minimizando riesgos y garantizando una experiencia de usuario confiable y segura.

2. Criterios de calidad

Atlas debe cumplir con los siguientes estándares, alineados con el negocio, el tipo de software y las especificaciones detalladas en el ERS.

2.1 Calidad en cuanto a usabilidad, rendimiento, estabilidad, confiabilidad y mantenibilidad

- Usabilidad: Interfaces con tipografía legible (mínimo 12px), contraste adecuado, controles grandes para usuarios mayores, etiquetas ARIA en formularios, navegación por teclado y elementos de UI con tamaño mínimo para pantallas táctiles (NFR-USAB-1, NFR-USAB-2, NFR-USAB-3, NFR-USAB-4). Flujos claros para registro y creación de empresas.

- Rendimiento: Tiempo de respuesta para operaciones CRUD simples < 300 ms bajo carga normal (NFR-PERF-1); página principal carga en < 2s en conexión móvil promedio (NFR-PERF-2); soporte para al menos 200 usuarios concurrentes (NFR-PERF-3).

- Estabilidad: Disponibilidad objetivo del 99.5% mensual (NFR-DIS-1); actualizaciones con ventana de mantenimiento y migración de datos segura (NFR-DIS-2).

- Confiabilidad: Gestión de logs segura (NFR-SEG-6); políticas de respaldo y recuperación definidas (NFR-SEG-7); integridad de la información mediante validación y saneamiento de entradas (NFR-SEG-5).

- Mantenibilidad: Código organizado en capas (Frontend React, Backend Express, DB PostgreSQL); documentación de API mediante Swagger; uso de estándares y dependencias actualizadas (React v19.1.1, Material UI v7.3.4, Tailwind v3.4.14, Express v4.19.2, etc.).

2.2 Seguridad relacionada a protección de datos, control de acceso, manejo de errores e integridad de la información

- Protección de datos: TLS obligatorio en todas las comunicaciones (NFR-SEG-1); hashing de contraseñas con bcrypt (NFR-SEG-2); encriptación de datos sensibles en reposo (NFR-SEG-3); cumplimiento de normativas de protección de datos personales (NFR-SEG-8).

- Control de acceso: Control de acceso por rol en backend (NFR-SEG-4); manejo de sesión mediante JWT (NFR-SEG-9); reglas de negocio RB-2, RB-4, RB-5 que restringen acciones según rol (administrador/editor).

- Manejo de errores: Mensajes de error amigables (NFR-USAB-3); validación server-side en todos los endpoints; protección contra CSRF, XSS, SQL Injection (NFR-SEG-5).

- Integridad de la información: Auditoría de acciones críticas (RF-6.1); eliminación lógica con confirmación (RF-4.2); validaciones en campos, formato y números alfanuméricos (RF-4.3).

2.3 Normativas en cuanto a estándares técnicos, leyes y políticas internas

- Estándares técnicos: Uso de stack definido (React, Express, PostgreSQL); API RESTful JSON; JWT para autenticación; TLS para comunicaciones; bcrypt para hashing.

- Leyes: Ley 19.628 sobre Protección de la Vida Privada; Ley 21.096 que consagra el derecho a la protección de datos personales; normativas chilenas sobre comercio electrónico y documentos digitales.

- Políticas internas: Política de contraseñas (mínimo 12 caracteres, incluir mayúsculas, minúsculas, número y símbolo); política de respaldo y recuperación; política de auditoría y logs.

3. Plan de pruebas

3.1 Estrategia de pruebas

La estrategia de pruebas para Atlas será mixta, combinando pruebas manuales y automatizadas, con el fin de cubrir tanto aspectos funcionales como no funcionales, y garantizar la calidad, seguridad y cumplimiento normativo.

Enfoque:

- Mixto. Las pruebas funcionales y de usabilidad se ejecutarán manualmente para evaluar la experiencia de usuario y la accesibilidad; las pruebas de regresión, rendimiento y seguridad se automatizarán para garantizar repetibilidad y eficiencia.

Etapas del proceso:

1.- Planificación: Definición de alcance, objetivos, recursos y cronograma.

2.- Diseño de casos de prueba: Elaboración de casos basados en requerimientos funcionales y no funcionales del ERS.

3.- Preparación del entorno: Configuración de ambientes de desarrollo, QA y preproducción.

4.- Ejecución: Pruebas manuales y automatizadas según priorización.

5.- Registro de resultados: Documentación de hallazgos, defectos y evidencias.

6.- Re-testeo y regresión: Verificación de correcciones y aseguramiento de no regresiones.

7.- Cierre: Informe final de pruebas y métricas de calidad.

Herramientas que se podrían utilizar:

- Automatización: Selenium, Cypress, Postman (para API), JMeter (rendimiento).
- Seguridad: OWASP ZAP, Burp Suite, Nessus.
- Usabilidad: Test con usuarios reales (incluyendo adultos mayores), herramientas de accesibilidad como axe DevTools.
- Gestión: Jira, TestRail, GitLab CI/CD.
- Priorización de pruebas:
- Alta prioridad: Autenticación y sesión (RF-1), control de acceso por roles (RF-3), seguridad (NFR-SEG), integridad de datos (RF-4, RF-5), auditoría (RF-6).
- Media prioridad: Rendimiento (NFR-PERF), usabilidad (NFR-USAB), compatibilidad (NFR-COMPAT).
- Baja prioridad: Mantenibilidad, documentación.

Criterios de entrada y salida:

- Entrada: Requerimientos aprobados, entorno de pruebas configurado, casos de prueba diseñados y revisados, datos de prueba preparados.
- Salida: Todos los casos de prueba ejecutados, defectos críticos y altos corregidos y retesteados, métricas de calidad dentro de umbrales aceptables, informe de pruebas aprobado.

3.2 Tipos de prueba

Se realizarán los siguientes tipos de prueba, cada uno con su justificación:

- Pruebas funcionales: Verifican que el sistema cumpla con los requerimientos funcionales (RF-1 a RF-6). Son esenciales para asegurar que las funcionalidades de autenticación, registro, gestión de clientes, contratos, documentos, usuarios y auditoría operen correctamente.

- Pruebas no funcionales: Evalúan atributos de calidad como rendimiento, usabilidad, disponibilidad y compatibilidad. Son necesarias para garantizar una experiencia de usuario adecuada y el cumplimiento de NFR-PERF, NFR-USAB, NFR-DIS y NFR-COMPAT.

- Pruebas de seguridad: Verifican la protección contra CSRF, XSS, SQL Injection, control de acceso por rol, hashing de contraseñas, TLS, JWT y cumplimiento normativo. Son críticas debido a la sensibilidad de los datos gestionados.

- Pruebas de integración: Aseguran que los componentes del sistema (Frontend React, Backend Express, PostgreSQL) interactúen correctamente, incluyendo la API RESTful y el almacenamiento de documentos.

- Pruebas de usabilidad: Evalúan la facilidad de uso, accesibilidad y experiencia de usuario, especialmente para adultos mayores. Son requeridas por NFR-USAB y los criterios de aceptación del ERS.

- Pruebas de rendimiento: Miden tiempos de respuesta, carga concurrente y estabilidad bajo condiciones de estrés. Son necesarias para validar NFR-PERF.

- Pruebas de compatibilidad: Verifican el correcto funcionamiento en navegadores modernos (Chrome, Firefox, Safari, Edge) y dispositivos móviles/tablets. Requeridas por NFR-COMPAT.

- Pruebas de regresión: Aseguran que los cambios no introduzcan defectos en funcionalidades existentes. Se ejecutarán después de correcciones o nuevas versiones.

3.3 Criterios de aceptación

Los criterios de aceptación transversales para que los casos de prueba sean considerados aprobados son:

3.3.1 Funcionales

- El sistema realiza correctamente la operación descrita en el requerimiento.
- Los datos ingresados se validan según las reglas de negocio y restricciones.
- Los mensajes de error son claros y amigables.
- La auditoría registra la acción crítica correspondiente.

3.3.2 No funcionales

- Tiempo de respuesta < 300 ms para CRUD simples.
- Página principal carga en < 2s en conexión móvil promedio.
- Soporte para al menos 200 usuarios concurrentes sin degradación significativa.
- Disponibilidad del 99.5% mensual.
- Interfaz accesible: tipografía legible, contraste adecuado, controles grandes, etiquetas ARIA, navegación por teclado.
- Compatibilidad con últimas 2 versiones de Chrome, Firefox, Safari y Edge.
- Responsivo para móviles y tablets.

3.3.3 Reglas de negocio

- RB-1: Un correo no puede existir en dos empresas como correo principal.

- RB-2: Solo usuarios con relación en empresa_usuarios pueden ver o editar datos de la empresa.
- RB-3: Un contrato se asocia únicamente a un cliente.
- RB-4: Un editor sólo tiene permisos de lectura.
- RB-5: Un administrador tiene acceso completo a operaciones CRUD.

3.3.4 Seguridad

- TLS en todas las comunicaciones.
- Contraseñas hasheadas con bcrypt.
- Datos sensibles encriptados en reposo.
- Control de acceso por rol en backend.
- Protección contra CSRF, XSS, SQL Injection.
- Gestión de logs segura.
- Políticas de respaldo y recuperación definidas.
- Cumplimiento de normativas de protección de datos personales.
- Manejo de sesión mediante JWT.

3.4 Herramientas utilizadas

Herramienta	**Tipo de prueba**	**Fundamento**
Selenium	Funcional, regresión	Automatización de pruebas web en múltiples navegadores.
Cypress	Funcional, integración	Pruebas end-to-end rápidas y confiables para aplicaciones React.
Postman	API, integración	Pruebas manuales y automatizadas de endpoints REST.
JMeter	Rendimiento, carga	Simulación de carga concurrente y medición de tiempos de respuesta.
OWASP ZAP	Seguridad	Escaneo de vulnerabilidades web (CSRF, XSS, SQL Injection).
Burp Suite	Seguridad	Pruebas de penetración y análisis de seguridad.
axe DevTools	Usabilidad/accesibilidad	Evaluación de accesibilidad web (ARIA, contraste, navegación).
Jira	Gestión	Seguimiento de defectos y tareas de prueba.
TestRail	Gestión	Administración de casos de prueba

		y resultados.
GitLab CI/CD	Automatización	Integración continua y ejecución automatizada de pruebas.

Recursos necesarios:

Humanos:

- Líder de pruebas (1)
- Ingeniero de pruebas funcionales (2)
- Ingeniero de pruebas de seguridad (1)
- Ingeniero de pruebas de rendimiento (1)
- Diseñador UX/UI para pruebas de usabilidad (1)
- Usuarios finales para pruebas de usabilidad (5 adultos mayores representativos)

Técnicos:

- Computadores con navegadores modernos (Chrome, Firefox, Safari, Edge)
- Dispositivos móviles y tablets para pruebas de compatibilidad
- Servidores de prueba (desarrollo, QA, preproducción)
- Herramientas de software listadas arriba
- Datos de prueba sintéticos y reales anonimizados

Entorno de prueba:

- Ambiente de desarrollo: para pruebas unitarias e integración temprana.
- Ambiente QA: para pruebas funcionales, no funcionales y de seguridad.
- Ambiente de preproducción: para pruebas de aceptación y usabilidad.

4. Diseño de casos de prueba

A continuación se presentan 5 casos de prueba representativos, cubriendo diferentes tipos de requerimientos del ERS.

Caso de prueba CP-01: Autenticación exitosa

Campo	**Descripción**
ID	**CP-01**
Nombre	Autenticación exitosa con credenciales válidas
Requerimiento	RF-1.1
Descripción	Verificar que un usuario pueda autenticarse con nombre_usuario y contraseña correctos.

Precondiciones	Usuario registrado y activo en el sistema.
Pasos	1. Acceder a la página de login. 2. Ingresar nombre_usuario válido. 3. Ingresar contraseña válida. 4. Hacer clic en "Iniciar sesión".
Resultado esperado	El sistema genera un token JWT y redirige al Dashboard de la empresa.
Criterio de aceptación	Login exitoso genera token de sesión (JWT); usuario accede al Dashboard.
Datos de prueba	usuario: `admin@empresa.cl`, contraseña: `Admin1234!`
Tipo de prueba	Funcional, seguridad

Caso de prueba CP-02: Control de acceso por rol (editor no puede editar)

Campo	**Descripción**
ID	**CP-02**
Nombre	Editor no puede editar clientes
Requerimiento	RF-3.2, RB-4
Descripción	Verificar que un usuario con rol editor solo pueda visualizar datos, no editarlos.
Precondiciones	Usuario con rol editor autenticado.
Pasos	1. Iniciar sesión como editor. 2. Ir a la sección de clientes. 3. Intentar editar un cliente existente. 4. Intentar eliminar un cliente.
Resultado esperado	El sistema muestra los datos en modo solo lectura; los botones de editar/eliminar están deshabilitados o ausentes.
Criterio de aceptación	El editor no puede acceder a recursos de otros roles (creación, edición o eliminación).
Datos de prueba	usuario: `editor@empresa.cl`, contraseña: `Editor1234!`
Tipo de prueba	Funcional, seguridad

Caso de prueba CP-03: Creación de contrato con documento adjunto

Campo	Descripción
ID	**CP-03**
Nombre	Creación de contrato y carga de documento PDF
Requerimiento	RF-5.1, RF-5.2, RF-5.3
Descripción	Verificar que un usuario pueda crear un contrato asociado a un cliente y adjuntar un documento PDF.
Precondiciones	Usuario autenticado con rol administrador; cliente existente.
Pasos	1. Ir a la sección de contratos. 2. Hacer clic en "Nuevo contrato". 3. Seleccionar cliente. 4. Ingresar título, descripción, fecha de inicio y fecha de término. 5. Adjuntar archivo PDF. 6. Guardar contrato.
Resultado esperado	El contrato se crea correctamente; el documento se almacena en storage interno y se referencia en la BD.
Criterio de aceptación	La subida y descarga debe considerar un tiempo no mayor a 10 segundos. El estado del contrato se calcula según fechas.
Datos de prueba	Cliente: `Empresa XYZ`, título: `Contrato de servicio`, fechas: `2026-05-01` a `2027-05-01`, archivo: `contrato.pdf`
Tipo de prueba	Funcional, integración, rendimiento

Caso de prueba CP-04: Prueba de seguridad – Protección contra SQL Injection

Campo	Descripción
ID	**CP-04**
Nombre	Protección contra SQL Injection en login
Requerimiento	NFR-SEG-5
Descripción	Verificar que el sistema esté protegido contra ataques de inyección SQL en el formulario de login.
Precondiciones	Aplicación desplegada en ambiente QA.
Pasos	1. Acceder al login.

	2. Ingresar en nombre_usuario: `' OR '1'='1`. 3. Ingresar cualquier contraseña. 4. Hacer clic en "Iniciar sesión".
Resultado esperado	El sistema rechaza la autenticación y muestra un mensaje de error genérico. No se ejecuta la consulta maliciosa.
Criterio de aceptación	Auditoría de seguridad con checklist y pruebas de penetración sin hallazgos críticos.
Datos de prueba	usuario: `' OR '1'='1`, contraseña: `test`
Tipo de prueba	Seguridad

Caso de prueba CP-05: Prueba de usabilidad con adulto mayor

ID	**CP-05**
Nombre	Usabilidad para adulto mayor en registro y creación de empresa
Requerimiento	NFR-USAB-1, NFR-USAB-2, NFR-USAB-4
Descripción	Evaluar la facilidad de uso del flujo de registro y creación de empresa para un usuario adulto mayor.
Precondiciones	Usuario adulto mayor (60+ años) sin experiencia previa en el sistema.
Pasos	1. Acceder a la página de registro. 2. Completar formulario de registro. 3. Confirmar registro. 4. Crear empresa. 5. Navegar al Dashboard.
Resultado esperado	El usuario completa el flujo sin bloqueos mayores, comprendiendo las instrucciones y mensajes.
Criterio de aceptación	Pruebas de usabilidad con usuarios mayores (5 usuarios representativos) no muestran bloqueos mayores y cumplimiento básico de accesibilidad. Score de usabilidad mínimo aceptable.
Datos de prueba	Usuario: `maria.lopez@email.cl`, contraseña: `Maria1234!`, empresa: `Mi Pyme`
Tipo de prueba	Usabilidad, accesibilidad